医疗影像安全完整必备功能（适配PACS、影像采集终端、云影像、符合YY/T1861、等保2.0、个保法、DICOM PS3.15）

整体分为**身份访问安全、DICOM通信安全、数据加密与完整性、隐私脱敏去标识、操作审计追溯、存储容灾备份、终端与网络安全、数据生命周期管控、安全应急与合规、设备辐射安全**十大模块。

一、可信身份与细粒度访问控制（源头防越权）

1. 多因素强身份认证

1. 支持**账号密码+UKey/数字证书（国密SM2）/指纹/人脸/动态验证码**二/三因子登录，禁止单一弱密码登录；
2. 密码复杂度策略：长度≥8位，大小写+数字+特殊字符，定期强制更换、锁定多次失败账号；
3. 统一4A身份对接，院内HIS/RIS/PACS账号互通，实习/进修人员限时临时账号、到期自动回收权限。

2. DICOM节点鉴权（设备通信准入）

- 可配置合法AE Title、IP、端口白名单，拒绝未知设备C-STORE/C-MOVE/C-FIND请求；
- 按设备区分权限：仅允许CT/MRI上传，不允许任意设备下载、删除影像。

3. RBAC最小权限管控

- 角色分级：技师（仅上传）、诊断医师（调阅+写报告）、科主任（批量导出/审批）、管理员（系统配置，不可查看患者影像）、科研（仅脱敏数据）；
- 字段级权限：普通医生仅看本院患者，跨院会诊需人工审批；可限制仅能查看自身分管患者；
- 临时授权机制：会诊、教学可发放限时临时权限，到期自动失效，支持一键撤销。

二、DICOM通信传输安全（防窃听、中间人篡改）

1. **DICOM TLS加密传输**（DICOM PS3.15标准），院内、跨院、远程访问全部启用TLS1.3，禁止明文DICOM通信；
2. 远程访问支持国密SSL/VPN隧道，公网会诊不走裸DICOM端口；
3. 通信完整性校验：DICOM数据流传输前后校验MD5/SM3哈希，中途篡改直接丢弃重传；
4. 端口管控：关闭DICOM默认开放高危端口，仅白名单IP放行；防火墙隔离放射内网与办公外网。

三、全链路数据加密（静态存储+动态传输，国密合规）

1. 存储静态加密

- 影像文件全盘/文件级加密，优先**国密SM4**，兼容AES256；DICOM原始文件落盘自动加密，硬盘失窃无法读取原始影像；
- 密钥全生命周期管理：硬件加密机存储密钥、定期轮换、双人保管根密钥，禁止硬编码密钥；
- 数据库元数据（患者姓名、身份证、检查记录）字段加密存储。

2. 传输动态加密

- 内网DICOM TLS、外网会诊国密VPN、Web阅片HTTPS/TLS1.3；
- 离线导出（U盘/光盘）：导出包加密，需授权密码打开，禁止明文拷贝原始DICOM。

3. 完整性防篡改

- DICOM文件附加SM3数字签名，任意修改像素/头文件信息即可校验失败；
- 关键报告、诊断记录支持电子签章（国密SM2签名），不可篡改、不可抵赖。

四、患者隐私保护：脱敏、去标识、水印（满足《个人信息保护法》）

1. DICOM头文件自动脱敏/去标识化

- 自动清除/替换敏感字段：姓名、身份证、手机号、住址、出生日期、医保号；
- 区分两种模式：1）临时会诊脱敏：仅隐藏敏感信息，保留唯一关联ID，可溯源；2）科研匿名化：彻底剥离所有标识，无法反向关联患者；
- 支持手动脱敏、批量脱敏，导出/共享前强制脱敏校验，未脱敏禁止外传。

2. 图像数字水印（不可移除溯源）

1. 明水印：右下角嵌入患者编号、机构、操作人；
2. 隐形鲁棒水印：嵌入像素底层，截图、裁剪、导出后仍可提取操作者、时间、设备信息；
3. 离线拷贝、截图、打印自动追加水印，防止私自外传泄露。

3. 打印管控

- 打印影像自带水印，记录打印人、时间；禁止无授权批量打印；打印日志留存审计。

五、全行为审计追溯（等保强制要求，日志留存≥6个月，核心数据≥3年）

1. **全操作日志记录：** 登录登出、影像上传/调阅/下载/删除/打印、报告修改、跨院会诊导出、权限变更、系统配置、批量删除、脱敏操作；
2. 日志字段完整：操作人、账号、终端IP、设备AE、患者ID、影像序列、操作时间、操作结果；
3. 日志防篡改：日志库独立存储、只读、不可删除，支持区块链存证；
4. 审计检索：按患者、人员、时间、操作类型快速溯源；
5. 异常行为自动告警：批量下载、异地多次调阅、非工作时间大量访问、多次失败登录。

六、存储容灾与数据生命周期安全（防丢失、勒索病毒）

1. **多副本冗余存储**：在线RAID5/6、近线归档、离线备份三级架构，杜绝单点故障；
2. 定时自动备份：每日增量、每周全量，**异地灾备**（跨机房/跨院区）；
3. 备份恢复演练：每季度抽样恢复校验，确保勒索病毒、硬件损坏后可完整找回影像；
4. 数据生命周期管理：
    - 短期在线（1–3年）快速调阅；中长期归档至低成本存储；
    - 到期数据按法规自动归档/离线封存，销毁支持不可逆粉碎删除；
5. 防勒索防护：存储读写权限隔离，禁止PACS服务器直接外网访问，定期快照回滚。

七、终端与外接设备安全（采集工作站、阅片电脑）

1. 终端准入：放射工作站IP/MAC绑定，外来电脑禁止接入影像内网；

2. 外设管控：限制USB只读，导出影像必须走系统加密导出通道，禁止直拷原始DICOM；
3. 终端安全：统一杀毒、补丁更新，屏幕防截屏水印、远程阅片禁止本地缓存原始影像；
4. 移动设备（平板/手机阅片）：APP加密缓存、退出自动清缓存、远程设备销毁功能。

八、数据共享与对外交互安全（医联体、远程会诊、科研）

1. 跨机构共享审批流程：申请→科室主任审批→自动脱敏→加密传输→操作留痕；
2. 数据使用边界管控：科研数据仅允许脱敏影像，禁止带出医院原始标识；
3. 第三方接口安全（HIS、AI辅助诊断、医保）：接口鉴权、请求频率限流、数据输出脱敏、接口日志审计；
4. 禁止原始影像无限制对外输出，所有对外分发均可溯源。

九、安全监测、告警与应急处置

1. 实时流量监测：DICOM异常大量传输、陌生IP访问、批量下载实时告警；
2. 入侵检测IDS/IPS：识别暴力破解、端口扫描、恶意篡改DICOM数据流；
3. 安全事件闭环：泄露/越权访问自动生成处置工单，留存处置记录；
4. 应急机制：勒索病毒隔离、账号紧急冻结、可疑病例访问一键阻断。

十、合规配套管理功能（满足医卫数据安全办法、YY/T1861、等保三级）

1. 安全策略配置中心：统一开关加密、水印、脱敏、日志、访问白名单；
2. 安全自查报表：权限审计、异常访问统计、备份有效性、脱敏记录；
3. 操作人安全培训记录、外部服务商访问审批与保密协议管理；
4. 国密算法合规适配、密评支撑功能；
5. 分级分类管理：区分核心/重要/一般医疗影像数据，差异化防护强度。

十一、放射设备物理辐射安全（影像设备硬件安全，配套软件联动）

1. 机房联锁、射线曝光状态指示灯、电离辐射警示；
2. 扫描剂量记录留存，符合ALARA低剂量原则；
3. 设备故障自动停机、剂量超阈值告警，人员防护管理记录。

极简落地优先级（开发/产品选型参考）

1. 必做（等保+法规硬性）：身份多因子、DICOM TLS加密、操作审计日志、存储加密、水印脱敏、AE/IP白名单、备份容灾；
2. 进阶（三甲/云影像）：国密套件、数字签名、临时授权、异地灾备、异常行为告警；
3. 高阶（科研/医联体）：区块链存证、联邦学习脱敏、细粒度跨院共享审批。